

Security operations (28%)

4.1 Security Techniques to Computing Resources

Secure Baselines – Establish a known-good configuration; deploy consistently; maintain through ongoing monitoring and drift detection

Hardening Targets:

- **Mobile devices** – MDM enrollment, screen lock, remote wipe, disable unused radios
- **Workstations** – AV/EDR, host firewall, patch OS and apps, disable unnecessary services
- **Switches/Routers** – Disable unused ports, change default credentials, enable port security
- **Cloud infrastructure** – Enforce IAM least privilege, enable logging, restrict public exposure
- **Servers** – Harden OS, remove unneeded roles, enforce encryption
- **ICS/SCADA** – Isolate from corporate network; apply compensating controls
- **Embedded/RTOS** – Fixed firmware; update when vendor releases patches; physically secure
- **IoT devices** – Change defaults; segment onto isolated VLAN; monitor traffic

Wireless Devices

- **Site surveys** – Map coverage, identify dead zones, locate rogue APs
- **Heat maps** – Visual overlay of signal strength across physical space

Mobile Solutions

- **MDM (Mobile Device Management)** – Centrally manage, enforce policy, remote wipe
- **BYOD** – Employee-owned; org must define acceptable use boundaries
- **COPE** – Corporate-Owned, Personally Enabled; org controls device, allows personal use
- **CYOD** – Choose Your Own Device; employee picks from approved list

Connection Methods: Cellular, Wi-Fi, Bluetooth — each requires its own security policy

Wireless Security Settings

- **WPA3** – Current Wi-Fi encryption standard; replaces WPA2
- **RADIUS** – Centralized AAA server for wireless and wired auth (802.1X)
- **Cryptographic protocols** – EAP variants (EAP-TLS, PEAP) for mutual auth
- **Authentication protocols** – Must match between client and RADIUS server

Application Security

- **Input validation** – Reject malformed/unexpected input before processing
- **Secure cookies** – HTTPOnly + Secure flags prevent theft via JS or cleartext
- **Static code analysis** – Scan source code for vulnerabilities before compilation
- **Code signing** – Verify code integrity and authorship with a digital signature

Sandboxing – Isolate app/code in a restricted environment to contain any impact

Monitoring – Continuously observe systems for anomalies, policy violations, and indicators of compromise

4.2 Hardware, Software & Data Asset Management

Acquisition/Procurement – Vet vendors for security practices before purchasing hardware or software

Assignment/Accounting

- **Ownership** – Assign a responsible party to every asset
- **Classification** – Tag assets by sensitivity level to apply appropriate controls

Monitoring/Asset Tracking

- **Inventory** – Maintain a complete list of all hardware and software assets
- **Enumeration** – Discover and catalog assets (known and unknown) on the network

Disposal/Decommissioning

- **Sanitization** – Wipe media so data is unrecoverable (overwrite, degauss)

- **Destruction** – Physical shredding/crushing for highest sensitivity media
- **Certification** – Third-party proof that destruction was completed properly
- **Data retention** – Keep data only as long as required by policy/regulation; then destroy

4.3 Vulnerability Management

Identification Methods

- **Vulnerability scan** – Automated tool checks systems for known CVEs and misconfigs
- **Static analysis** – Review source code without executing it
- **Dynamic analysis** – Test running application (DAST) for runtime vulnerabilities
- **Package monitoring** – Track dependencies for newly disclosed vulns
- **Threat feed** – External intel on active threats and new vulnerabilities:
 - OSINT – Publicly available sources
 - Proprietary/third-party – Commercial threat intel
 - Information-sharing orgs – ISACs
 - Dark web – Attacker forums and leaked data
- **Penetration testing** – Authorized simulated attack to find exploitable weaknesses
- **Responsible disclosure / Bug bounty** – Researchers report vulns in exchange for reward
- **System/process audit** – Review configurations and procedures for security gaps

Analysis

- **False positive** – Scan flags a vulnerability that doesn't actually exist
- **False negative** – Scan misses a vulnerability that does exist
- **Prioritize** – Address critical and actively exploited vulns first
- **CVSS (Common Vulnerability Scoring System)** – 0–10 numeric score rating severity

- **CVE (Common Vulnerability Enumeration)** – Standardized naming for known vulnerabilities
- **Vulnerability classification** – Categorize by type (injection, overflow, misconfiguration, etc.)
- **Exposure factor** – Percentage of asset value lost if a vuln is exploited
- **Environmental variables** – Local conditions that raise or lower effective risk
- **Risk tolerance** – Organization's accepted level of residual risk

Vulnerability Response & Remediation

- **Patching** – Apply vendor fix; highest priority action
- **Insurance** – Transfer residual financial risk
- **Segmentation** – Isolate vulnerable systems to limit blast radius
- **Compensating controls** – Temporary mitigations when patching isn't possible
- **Exceptions and exemptions** – Documented, risk-accepted deviations from policy

Validation of Remediation

- **Rescanning** – Re-run the scan to confirm the vulnerability is gone
- **Audit** – Independent review to verify remediation was completed correctly
- **Verification** – Confirm the fix works without reintroducing issues

Reporting – Document findings, risk ratings, remediation status, and trends over time

4.4 Security Alerting & Monitoring

Monitoring Computing Resources – Cover systems, applications, and infrastructure continuously

Activities

- **Log aggregation** – Collect logs from all sources into a central system
- **Alerting** – Trigger notifications when rules or thresholds are crossed
- **Scanning** – Regularly probe for vulnerabilities and misconfigurations
- **Reporting** – Summarize findings for stakeholders and compliance

- **Archiving** – Retain logs for forensic and compliance purposes
- **Alert response** – Investigate alerts; remediate confirmed findings
- **Quarantine** – Isolate affected systems pending investigation
- **Alert tuning** – Reduce false positives; refine rules to improve signal-to-noise ratio

Tools

- **SCAP (Security Content Automation Protocol)** – Standardized framework for automated compliance checking
 - **Benchmarks** – Hardening baselines (CIS Benchmarks, DISA STIGs)
 - **Agents/Agentless** – Agent = software installed on endpoint; Agentless = network-based queries
 - **SIEM (Security Information & Event Management)** – Aggregates and correlates logs; generates alerts; central visibility platform
 - **Antivirus** – Signature + heuristic detection of known malware
 - **DLP (Data Loss Prevention)** – Detects and blocks unauthorized data exfiltration
 - **SNMP traps** – Network device sends alert to management system on status change
 - **NetFlow** – Network traffic metadata (who talked to whom, how much, when); no packet content
 - **Vulnerability scanners** – Automated tools that identify known CVEs and misconfigs (Nessus, Qualys, OpenVAS)
-

4.5 Enhance Enterprise Security Capabilities

Firewall

- **Rules** – Permit/deny traffic based on IP, port, protocol, direction
- **Access lists (ACLs)** – Applied per interface; ordered list of permit/deny statements
- **Ports/protocols** – Block unused; allow only what's necessary
- **Screened subnets** – DMZ between two firewalls; semi-trusted zone for public-facing servers

IDS/IPS

- **Trends** – Detect behavioral changes over time (baseline deviation)
- **Signatures** – Pattern-match against known attack fingerprints

Web Filter

- **Agent-based** – Software on endpoint enforces policy even off-network
- **Centralized proxy** – All traffic routed through filtering proxy
- **URL scanning** – Check links for malicious content before allowing access
- **Content categorization** – Block by category (gambling, adult, malware)
- **Block rules** – Explicit deny list for known-bad domains/IPs
- **Reputation** – Score-based allow/deny using threat intel feeds

Operating System Security

- **Group Policy** – Windows domain-wide policy enforcement (passwords, restrictions, software)
- **SELinux** – Mandatory access control for Linux; enforces strict process isolation

Secure Protocol Implementation

- **Protocol selection** – Use TLS 1.3, SSH v2, SNMPv3; avoid older versions
- **Port selection** – Move services off default ports to reduce automated scanning
- **Transport method** – Enforce encryption in transit; disable cleartext protocols

DNS Filtering – Block resolution of known-malicious domains at the DNS layer

Email Security

- **DMARC** – Policy that tells receivers what to do with mail that fails SPF/DKIM
- **DKIM** – Cryptographic signature added to outbound email; verifies sending domain
- **SPF** – Specifies which IPs are authorized to send email for a domain
- **Gateway** – Email security gateway filters spam, malware, and phishing before delivery

File Integrity Monitoring (FIM) – Detects unauthorized changes to critical system files

DLP (Data Loss Prevention) – Monitors and blocks sensitive data leaving the network

Network Access Control (NAC) – Checks device posture before granting network access

EDR/XDR

- **EDR (Endpoint Detection & Response)** – Monitors endpoints for threats; enables investigation and response
- **XDR (Extended Detection & Response)** – EDR extended across network, cloud, and identity

User Behavior Analytics (UBA) – Baselines normal user behavior; alerts on deviations (insider threat detection)

4.6 Identity & Access Management (IAM)

Provisioning/De-provisioning – Create accounts when users join; promptly remove when they leave (critical for offboarding)

Permission Assignments – Follow least privilege; assign only what's needed for the role

Identity Proofing – Verify a person is who they claim before issuing credentials

Federation – Linking identities across organizations so one credential works in multiple systems

Single Sign-On (SSO) – One login grants access to multiple systems; reduces password fatigue

- **LDAP** – Directory protocol used for authentication lookups (on-prem)
- **OAuth** – Authorization framework; grants third-party access without sharing credentials
- **SAML** – XML-based standard for exchanging authentication assertions between IdP and SP

Interoperability – Different identity systems must be able to communicate and trust each other

Attestation – Periodic review confirming that access rights are still appropriate

Access Controls

- **Mandatory (MAC)** – OS enforces access based on labels; user cannot override
- **Discretionary (DAC)** – Owner sets permissions; most flexible, most risky
- **Role-Based (RBAC)** – Access granted by job role; easiest to manage at scale
- **Rule-Based** – Access determined by conditions/rules (time of day, IP range)
- **Attribute-Based (ABAC)** – Fine-grained; considers user, resource, and environment attributes
- **Time-of-day restrictions** – Limit access to business hours only
- **Least privilege** – Grant only the minimum access needed; review and revoke excess

Multifactor Authentication (MFA) – Require two or more factors from different categories:

- Something you **know** – Password, PIN
- Something you **have** – Authenticator app, hardware token, smart card
- Something you **are** – Fingerprint, retina scan, facial recognition
- **Somewhere you are** – GPS location, IP-based geofencing

MFA Implementations: Biometrics, hard tokens (physical device), soft tokens (app-based), security keys (FIDO2/WebAuthn)

Password Concepts

- **Length** – Minimum 12–16 characters; length beats complexity
- **Complexity** – Mix of character types; prevents simple dictionary attacks
- **Reuse** – Prohibit reusing recent passwords; enforce history
- **Expiration** – Rotate periodically; immediately on suspected compromise
- **Age** – Minimum age prevents immediate re-reuse to cycle back to old passwords
- **Password managers** – Securely store unique passwords for all accounts
- **Passwordless** – Replace passwords with FIDO2 keys, biometrics, or magic links

Privileged Access Management (PAM)

- **Just-in-time (JIT) permissions** – Elevate access only when needed; auto-expire after task
- **Password vaulting** – Store privileged credentials in a secure, audited vault
- **Ephemeral credentials** – Short-lived, auto-rotated credentials for privileged sessions

4.7 Automation & Orchestration

Use Cases of Automation & Scripting

- User provisioning – Auto-create/disable accounts based on HR events
- Resource provisioning – Spin up/down cloud resources via IaC
- Guard rails – Automated policy enforcement; block non-compliant actions
- Security groups – Auto-update firewall/ACL rules based on threat intel
- Ticket creation – Auto-generate incident tickets from SIEM alerts
- Escalation – Auto-escalate unacknowledged alerts after a threshold
- Enabling/disabling services – Turn off vulnerable services until patched
- Continuous integration/testing – Security scans embedded in the CI/CD pipeline
- API integrations – Tie security tools together for automated workflows

Benefits

- Efficiency/time saving – Tasks that took hours run in seconds
- Enforcing baselines – Consistent, repeatable configuration every time
- Standard infrastructure configurations – No configuration drift
- Scaling in a secure manner – Security grows with the environment
- Employee retention – Remove repetitive toil; security staff focus on higher-value work
- Reaction time – Automated response is faster than any human analyst
- Workforce multiplier – Small team can cover more with automation

Other Considerations

- **Complexity** – More automation = more code to maintain and debug
- **Cost** – Initial build investment; ongoing maintenance
- **Single point of failure** – If automation breaks, processes may halt
- **Technical debt** – Poorly built automation becomes a security risk itself
- **Ongoing supportability** – Must be documented and transferable

4.8 Incident Response

Process (PICERL)

1. **Preparation** – Policies, playbooks, tools, team training in place before an event
2. **Detection** – Identify that an incident has occurred (SIEM alert, user report, IOC)
3. **Analysis** – Determine scope, impact, and root cause of the incident
4. **Containment** – Limit the spread; isolate affected systems immediately
5. **Eradication** – Remove the threat (malware, attacker access, compromised accounts)
6. **Recovery** – Restore systems to known-good state; monitor for recurrence
7. **Lessons learned** – Post-incident review; update processes to prevent recurrence

Training – Regular tabletop and simulation exercises keep the team ready

Testing

- **Tabletop exercise** – Walk through a scenario verbally; identify gaps without system impact
- **Simulation** – Realistic drill (fake ransomware, phishing test); tests actual response

Root Cause Analysis – Identify the underlying cause, not just the symptom

Threat Hunting – Proactively search for hidden threats that evaded automated detection

Digital Forensics

- **Legal hold** – Preserve all relevant data once litigation/investigation is anticipated
- **Chain of custody** – Document every person who handles evidence to maintain integrity
- **Acquisition** – Collect forensic images using write blockers; preserve original media
- **Reporting** – Document findings in a clear, court-admissible format
- **Preservation** – Prevent alteration of evidence; store securely
- **E-discovery** – Legal process of finding and producing electronically stored information

4.9 Data Sources for Investigations

Log Data

- **Firewall logs** – Permitted/denied traffic; source/dest IPs and ports
- **Application logs** – Errors, logins, transactions within the app
- **Endpoint logs** – Process execution, file access, registry changes on the host
- **OS-specific security logs** – Windows Event Log, Linux syslog/auditd
- **IPS/IDS logs** – Detected and blocked attack signatures
- **Network logs** – Traffic flows, DNS queries, DHCP assignments
- **Metadata** – File timestamps, email headers, document properties

Data Sources

- **Vulnerability scans** – Show what was exposed at a point in time
- **Automated reports** – Scheduled outputs from SIEM/monitoring tools
- **Dashboards** – Real-time visualization of security posture
- **Packet captures** – Full network traffic content; most detailed but resource-intensive